パスワード類似性チェッカーの評価指標と比較実験

室原 成瑛[1]　野島 良[1,2,a)]　王 立華[1,2]

概要：パスワード変更時に，ユーザは過去に使用したパスワードをわずかに変更した類似パスワードを選択する傾向がある．この問題に対し，Berardi らは，パスワードから生成した n-gram を Bloom Filter に格納し，新規パスワードと過去のパスワードとの類似性を判定する方式を提案した．一方，石井らは，この方式に対する攻撃手法を示すとともに，MinHash と Secure Sketch を用いたパスワード類似性判定方式を提案している．本研究では，漏洩した実パスワードのデータセットを用いて，石井らが示した攻撃手法の有効性を再評価する．さらに，パスワード類似性チェッカーの有用性を評価するための指標を新たに定義するとともに，Berardi らの方式に Secure Sketch を組み込んだパスワード類似性検知方式を提案する．最後に，提案指標に基づいて，提案方式と石井らの方式との比較実験を行う．

キーワード：パスワード類似性, Bloom Filter, Secure Sketch, 評価指標, 復元攻撃

Evaluation Metrics and Comparative Experiments for Password Similarity Checkers

Seiei Murohara[1]　Ryo Nojima[1,2,a)]　Lihua Wang[1,2]

Abstract: When required to change their passwords, users tend to choose new passwords that differ only slightly from those they have previously used. To address this issue, Berardi et al. proposed a method that stores n-grams generated from previous passwords in a Bloom filter and determines the similarity between a newly entered password and previously used passwords. Ishii et al., meanwhile, demonstrated an attack against this method and proposed a password similarity checking scheme based on MinHash and Secure Sketch. In this study, we reassess the effectiveness of the attack proposed by Ishii et al. using a dataset of real-world leaked passwords. We also define new metrics for evaluating the practical utility of password similarity checkers and propose a password similarity detection scheme that incorporates Secure Sketch into the method proposed by Berardi et al. Finally, we conduct comparative experiments between our proposed scheme and the scheme proposed by Ishii et al. using the proposed evaluation metrics.

Keywords: Password similarity, Bloom filter, Secure sketch, Evaluation metric, Recovery attack

1. はじめに

パスワード認証は依然として多くの情報システムの主要な認証手段である．一方で，組織によっては有効期限ポリシにより定期的な変更が義務付けられており，ユーザは新しいパスワードとして，過去のパスワードをわずかに改変したもの（末尾の数字を繰り上げる，1 文字だけ置換する等）を選択しがちであることが大規模な実測調査により報告されている [1], [2]．その結果，形式的にはポリシに準拠していても実質的なパスワード空間は拡大せず，攻撃者から見た探索空間はほとんど減少しない．したがって，過去のパスワードと「同一」であることを禁止するだけでなく，「類似」したパスワードの再利用を検出・抑制することが課題となる．類似性を判定するには過去のパスワードに関する情報を保持する必要があるが，平文で保存

[1] 立命館大学
Ritsumeikan University
[2] 情報通信研究機構
National Institute of Information and Communications Technology
[a)] ryo-no@fc.ritsumei.ac.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

することは重大なリスクを伴う．この問題に対し Berardi ら [3] は，過去のパスワードから生成した n-gram 集合を Bloom Filter に格納し，新パスワードから得られる Bloom Filter との距離を測定して類似性を判定する方式を提案した．以降これを Berardi 方式と呼ぶ．しかしながら，類似度を外部から観測可能な形で提供する方式は，その応答を繰り返し利用することにより元のパスワード構造が段階的に推定される危険性を内包する．石井ら [13] は，Berardi 方式に対して距離応答を利用してパスワードを復元する Bubble 攻撃を示し，その対策として Min-wise hashing と Reed–Solomon 符号に基づく Secure Sketch を組み合わせた方式（以降 MinHash+RS 方式）を提案した．ここで二つの問題が残されている．第一に，石井らの Bubble 攻撃の評価は一様ランダムに生成した長さ 12 のパスワードに対して行われており，実際のユーザが選ぶパスワードに対する有効性は明らかでない．実パスワードの n-gram 分布は著しく偏っているうえ，攻撃者は既に大規模な辞書を保有しているため，攻撃の位置づけ自体が変わりうる．第二に，類似性チェッカーの有用性は「編集距離ごとの検出率の表」として報告されてきたが，この表は複数の編集距離にまたがる優劣を一意に定めない．理想的な検出率曲線からの二乗平均平方根誤差（RMSE）による要約も考えられるが，得られる値が確率として解釈できないうえ，すべての編集距離を等しく重み付けし，無関係なパスワードの誤検出を評価対象に含めていないという問題がある．本研究の貢献は次の三点である．

(1) **Berardi 方式の実データによる評価（第 3 章）．**漏洩パスワードデータセット rockyou[12] を用いて Bubble 攻撃を再評価し，(a) Bloom Filter 長 m が攻撃難易度を支配し，m を大きくするほど攻撃が容易になること，(b) 実パスワードでは辞書攻撃が比較基準となり，Bubble 攻撃の価値は辞書に載っていないパスワードにあること，(c) Bloom Filter の立っているビット数からパスワード長がほぼ正確に推定できることを示す．

(2) **評価指標の定義（第 4.1 節）．**理想的な検出率曲線からの重み付き L_1 距離 D_θ を定義する．これは運用時の期待誤判定確率に等しく（命題 1），前述の RMSE を特別な場合として含む一般化になっている．

(3) **提案方式と比較実験（第 4 章）．**Berardi 方式に BCH 符号 [10], [11] による Secure Sketch を組み込んだ方式（以降 Bloom+BCH 方式）を提案し，提案指標の下で MinHash+RS 方式と比較する．対応のあるブートストラップ検定により，提案方式が有意に理想に近く，かつより少ない記憶量でこれを達成することを示す．

本論文の構成は次の通りである．第 2 章で準備を述べ，第 3 章で漏洩データを用いた Bubble 攻撃実験を，第 4 章で対策案 2 方式の評価指標を用いた実運用上評価を述べる．これら二つの実験は独立している．第 5 章でまとめる．

2. 準備

2.1 ブルームフィルタ

ブルームフィルタ（Bloom Filter）[6], [7] は，集合に要素が含まれるかを判定するための空間効率の高い確率的データ構造であり，長さ m のビット配列と k 個の独立なハッシュ関数からなる．要素 x の挿入では k 個のハッシュ値に対応するビットを 1 に設定し，照会では対応するビットがすべて 1 であれば「存在する可能性が高い」と判定する．偽陰性は生じないが偽陽性が生じ，N 個の要素を格納したときの偽陽性率はおよそ $(1 - e^{-kN/m})^k$ で与えられる．

2.2 n-gram

n-gram とは，文字列を連続した n 個の要素に区切った部分列である．たとえば文字列 `password` の 3-gram は `pas`, `ass`, `ssw`, `swo`, `wor`, `ord` の 6 個となる．長さ L の文字列からは $L - n + 1$ 個の n-gram が得られる．

2.3 Min-wise hashing

Min-wise hashing[5] は，集合 S に対しランダム置換 P_i を用いて $h_i(S) = \min_{x \in S} P_i(x)$ を計算することで，Jaccard 類似度を確率的に保存する固定長ベクトルを与える．挿入・削除・転置といった編集操作が生じても多くの n-gram は共通に保たれるため，編集距離型の揺らぎに対してロバストな特徴抽出として機能する．

2.4 Secure Sketch

Secure Sketch [4] は，ノイズを含む入力 w' から元の秘密 w を一定の誤り範囲内で復元可能にする補助データ s を公開する方式である．線形符号 C を用いた code-offset 構成では，符号語 $c \in C$ をランダムに選び $s = w - c$ を公開する．復元時には $c' = w' - s = c + e$ を復号し，誤り e の重みが符号の訂正能力 t 以下であれば w が復元される．$[n, k]$ 符号を用いた場合，s の公開により失われるエントロピーは高々 $(n - k)\log_2 q$ ビットである．本研究ではシンボル単位の訂正に Reed–Solomon 符号 [8] を，ビット単位の訂正に BCH 符号 [10], [11] を用いる．これらの符号の構成と復号法の詳細は文献 [9] を参照されたい．

2.5 Berardi らのパスワード類似性チェッカー

Berardi ら [3] の方式では，登録済みパスワード P を n-gram に分割し，その集合を長さ m のブルームフィルタ BF_P に格納する．新パスワード P' に対しても同様に $\mathsf{BF}_{P'}$ を生成し，距離 $d(\mathsf{BF}_P, \mathsf{BF}_{P'})$ を測定して閾値と比較する．過去のパスワードを直接保存しない点で有用だが，**距離そ**

© 2026 Information Processing Society of Japan

のものが応答として観測可能であり，またデータベースにはブルームフィルタがそのまま保存される．

2.6 石井らの Bubble 攻撃と対策方式

石井ら [13] は，この距離応答を利用する復元攻撃を示した．文字集合を $\mathcal{C}$ として，長さ n の文字列 $\mathcal{C}^n$ を全探索し距離の小さいものを a 個保持する．以降，保持した各候補に 1 文字ずつ連接しては距離の小さいものを b 個保持する，という手続きを目標長に達するまで繰り返すビーム探索である．一様ランダムな長さ 12 のパスワードに対し復元成功率 1.00 を報告している．石井らは対策として，n-gram 集合に Min-wise hashing を適用して長さ n_{sig} の署名を得たのち，GF(2^6) 上の短縮 Reed–Solomon 符号による Secure Sketch を適用する MinHash+RS 方式を提案した．この方式は距離応答を返さず受理・拒否のみを返すため，Bubble 攻撃の前提を断つことができる．

2.7 脅威モデル

本研究では二種類の攻撃者を想定する．第一に，**距離応答を観測できる攻撃者**である．Berardi 方式では攻撃者は任意のクエリ P' に対して $d(\mathsf{BF}_{P'}, \mathsf{BF}_P)$ を得られる．攻撃者は文字集合を既知とするが，パスワード長は未知とする．第二に，**データベースを取得した攻撃者**である．Berardi 方式ではブルームフィルタ全体（m ビット）が，Secure Sketch を用いる方式では sketch が攻撃者の手に渡る．本研究ではこの公開情報量を安全性の指標として扱う．いずれの攻撃者も大規模な漏洩パスワード辞書を保有していると仮定する．

3. 漏洩データを用いた Bubble 攻撃実験

3.1 実験設定

漏洩パスワードデータセット rockyou.txt [12] の先頭 300 万行から，長さ 8 かつ英大小文字・数字（62 種）のみからなる 628,191 件を対象とした．rockyou は latin-1 符号化であり，UTF-8 として読むと行が破損するため latin-1 として読み込んでいる．n-gram 長 $n = 3$，ハッシュ関数数 $k = 3$，初期保持数 $a = 300$，ビーム幅 $b = 200$ とし，ブルームフィルタ長 $m \in \{64, 128, 256, 512, 1024, 2048\}$ を走査した．ターゲットの抽出，初期段の同点処理，およびビーム探索中の無作為化に用いる疑似乱数生成器の種は，全設定で同一の値に固定し，結果を再現可能にした．ターゲットは 200 件を ***1* 回だけ**抽出して全設定で共有する．石井らの実装は設定ごとにターゲットを抽出し直しており，設定間の比較が交絡していたためである．rockyou は概ね出現頻度順に並んでいることから，コーパスの上位半分（314,095 件）を攻撃者が保有する辞書とみなし，ターゲットを辞書内・辞書外に各 100 件ずつ層別した．石井らの実装には初期段の同点処理に関する問題がある．長さ n のプレフィックスは n-gram をちょうど 1 個しか持たないため Jaccard 指数の取りうる値が極端に少なく，最上位の値に多数の候補が同点で並ぶ．先行実装が用いる `nlargest` はこの同点を候補生成順，すなわち文字集合の並び順で解決するため，復元成功率が「先頭文字が文字集合の並びで早いか」に左右される．本実装では同点を無作為に解決し，比較のため生成順による解決も併記する．また，石井らはパスワード長を既知としていたが，実パスワードでは長さは不定である．そこで本実装ではブルームフィルタの立っているビット数 p から $\mathbb{E}[p] = m(1 - (1 - 1/m)^{kN})$ を N について解き，推定長 $\hat{L} = N + n - 1$ として攻撃を行う．

3.2 ブルームフィルタ長 m の影響

表 1 に結果を示す．m を大きくすると偽陽性が減り，初期段で同点となる候補数が $m = 64$ の 2910 個から $m = 2048$ の 6.0 個へ単調に減少する．長さ 8・$n = 3$ における真の n-gram 数は $8 - 3 + 1 = 6$ であるから，$m = 2048$ では同点群が真の n-gram 集合とほぼ一致しており，ブルームフィルタから元パスワードがほぼ一意に定まることを意味する．これに伴い復元成功率は 0.08 から 0.96 へ，出力と正解の平均編集距離は 7.20 から 0.11 へ改善する．

3.3 初期段の同点処理の影響

表 2 に，同点を生成順で解決した場合と無作為に解決した場合の比較を示す．同点群が大きい $m = 128$ において成功率は 0.80（95% 信頼区間 0.71–0.87）と 0.52（0.42–0.62）に乖離し，両者の信頼区間は重ならない．一方，同点群が十分小さい $m \geq 256$ では両者は完全に一致した．これは石井らの実装の数値が，同点群が大きい設定において実装上のアーティファクトに影響されていたことを示している．なお，距離の大小ではなく n-gram が BF_P に含まれるか否かのみで候補を絞る方式（同点処理に依存しない）では $m = 128$ で 0.65 となり，両者の中間の値を与えた．

3.4 辞書攻撃との比較

石井らは全数探索との比較により約 10^{16} 倍の高速化を報告しているが，ターゲットが実パスワードである場合，比較すべき相手は「辞書を順に試す攻撃者」である．辞書内のターゲットに対し，辞書攻撃は 100 件すべてを平均 162,764 回の候補評価で復元した．一方 Bubble 攻撃の候補評価数は平均 314,176 回であり，辞書内では辞書攻撃の方が約 2 倍安価である．しかし辞書外のターゲットに対しては，辞書攻撃は辞書を全件（314,095 件）試しても 100 件中 0 件しか復元できないのに対し，Bubble 攻撃は**ほぼ同一の候補評価数**（314,176 回）で 96–97% を復元した．すなわち Bubble 攻撃の価値は「攻撃者の辞書に載っていな

© 2026 Information Processing Society of Japan

表 1 ブルームフィルタ長 m が Bubble 攻撃に与える影響（辞書外ターゲット 100 件，同点は無作為に解決）．同点群は初期段で最上位の Jaccard 指数に並ぶ候補数．括弧内は Wilson 95% 信頼区間．

Table 1 Effect of Bloom filter size m on the Bubble attack.

m	同点群	復元成功率	編集距離	長さ誤差
64	2910	0.08 (0.04–0.15)	7.20	0.45
128	451	0.52 (0.42–0.62)	1.69	0.34
256	68	0.96 (0.90–0.98)	0.10	0.27
512	15	0.96 (0.90–0.98)	0.08	0.20
1024	7.0	0.96 (0.90–0.98)	0.09	0.15
2048	6.0	0.96 (0.90–0.98)	0.11	0.10

表 2 初期段の同点処理が復元成功率に与える影響（辞書外ターゲット 100 件）．「生成順」は候補生成順で同点を解決する実装（石井らの実装に相当）．

Table 2 Effect of tie-breaking in the initial stage on the recovery success rate.

m	生成順	無作為
64	0.14 (0.09–0.22)	0.08 (0.04–0.15)
128	0.80 (0.71–0.87)	0.52 (0.42–0.62)
256	0.96 (0.90–0.98)	0.96 (0.90–0.98)
≥ 512	0.96 (0.90–0.98)	0.96 (0.90–0.98)

いパスワードを，辞書攻撃と同等のコストで復元できる」点にある．この層別を行わない評価では攻撃の意義を正しく位置づけられず，全数探索との比較は実パスワードに対しては過大な主張となる．

3.5 パスワード長の漏えい

ブルームフィルタに格納される n-gram の個数は $L-n+1$ であり，パスワード長 L とともに単調に増加する．したがって，ビット配列のうち値が 1 であるビット（以下，立っているビットと呼ぶ）の個数 p はパスワード長の情報を含んでおり，格納された n-gram 数 N の増加に伴って確率的に増大する．そこで第 3.1 節で述べたように，p の期待値の式を N について解くことで長さを推定できる．この推定はブルームフィルタさえ得られれば距離応答を用いずに実行でき，攻撃者が最初に得る情報となる．実際，立っているビット数からの長さ推定は平均誤差 0.28 文字であり，83.8% のターゲットで誤差 0.5 文字未満であった．表 1 が示すように，この誤差は m が大きいほど小さくなる（$m = 64$ で 0.45 文字，$m = 2048$ で 0.10 文字）．すなわちブルームフィルタを保存するだけでパスワード長がほぼ正確に漏れ，攻撃者は探索空間をあらかじめ絞り込める．

3.6 考察

本実験から，m **は安全性パラメータとして働き，大きくするほど漏えいが増える**ことがわかる．一方で類似性判定の精度は m が大きいほど向上するため，Berardi 方式ではこの両者を同時に満たすことができない．Berardi ら [3] および石井ら [13] は本文中に m および k の値を記載していないが，本結果は攻撃の成否がこれらに強く依存することを示しており，当該方式を採用する際にはこれらのパラメータの明示が不可欠である．この困難は，距離応答を返さない方式によって解消できる．次章ではその二つの候補を比較する．

4. 対策案 2 方式の評価指標を用いた実運用上評価

4.1 評価指標の定義

パスワード類似性チェッカーを，登録アルゴリズム Enroll と判定アルゴリズム Check の組 $\Sigma = (\mathsf{Enroll}, \mathsf{Check})$ とし，パラメータ λ（n-gram 長，スケッチ長，訂正能力 t など）を持つとする．$s \leftarrow \mathsf{Enroll}(P)$ に対し $\mathsf{Check}_\lambda(s, P') \in \{0, 1\}$ を出力し，1 は「P' は P に類似する」という判定を表す．$\mathrm{lev}(\cdot,\cdot)$ を Levenshtein 距離，$\mathcal{D}_d$ を，Levenshtein 距離がちょうど d となるパスワード対 (P, P') の分布とする．（すなわち，$(P, P') \sim \mathcal{D}_d$ ならば $\mathrm{lev}(P, P') = d$ が確率 1 で成り立つ．）また，$\mathcal{D}_\infty$ を，距離に関する条件を課さず，二つのパスワード P と P' を対象とするパスワード集合から互いに独立に選ぶことで得られる対 (P, P') の分布とする．評価対象とする有限の Levenshtein 距離の最大値を D とし，距離の添字集合を

$$\mathcal{I} = \{1, \ldots, D\} \cup \{\infty\}$$

と定める．各 $d \in \mathcal{I}$ に対する検出率を

$$r_\Sigma^\lambda(d) = \Pr_{(P,P') \sim \mathcal{D}_d} \left[\mathsf{Check}_\lambda(\mathsf{Enroll}(P), P') = 1 \right] \quad (1)$$

© 2026 Information Processing Society of Japan

と定義する．また，d に対する検出率の変化を表す関数 $r_\Sigma^\lambda : \mathcal{I} \to [0,1]$ を検出率曲線と呼ぶ．$r_\Sigma^\lambda(\infty)$ は，互いに独立に選ばれたパスワードを誤って「類似」と判定する確率である．以下，Σ および λ が明らかな場合には，$r_\Sigma^\lambda(d)$ を単に $r(d)$ と略記する．特に，$r(\infty)$ は，互いに独立に選ばれたパスワード対を誤って「類似」と判定する確率である．運用上，元のパスワード P との編集距離が θ 以下であるパスワード P' を再利用とみなして拒否し，編集距離が θ を超えるものを受理するものとしたい．この運用方針においては，距離 $d \le \theta$ のパスワード対を確率 1 で「類似」と判定し，距離 $d > \theta$ のパスワード対を確率 0 で「類似」と判定することが理想である．そこで，理想検出率関数を

$$I_\theta(d) = \begin{cases} 1 & (d \le \theta), \\ 0 & (d > \theta) \end{cases} \tag{2}$$

と定義する．ただし，$\infty > \theta$ と約束し，$I_\theta(\infty) = 0$ とする．ここで，登録済みパスワード P と新たに入力されたパスワード P' の組 (P, P') をパスワード対と呼ぶ．実運用では，編集距離が小さいパスワード対と大きいパスワード対が同じ頻度で現れるとは限らない．実運用で行われるパスワード変更全体を考える．変更前のパスワードを P，変更後のパスワードを P' としたとき，編集距離が d となる変更の割合を π_d とする（$d = 1, \ldots, D$）．また，P と P' が独立に選ばれる場合の割合を π_∞ とする．これらをまとめて

$$\pi = (\pi_d)_{d \in \mathcal{I}}, \qquad \sum_{d \in \mathcal{I}} \pi_d = 1$$

と表す．π_∞ を含めることは，旧パスワードとは独立に選ばれた新パスワードを評価に反映するために重要である．実運用では，旧パスワードをわずかに変更した新パスワードだけでなく，旧パスワードとは独立に選ばれた新パスワードも入力される．一方，有限の編集距離 d をもつパスワード対の出現頻度は，d によって異なると考えられる．したがって，すべての d を同じ重みで評価するのではなく，π_d によって重み付けする．$d \in \{1, \ldots, D\}$ のパスワード対だけを評価すると，旧パスワードを編集して作られた新パスワードだけが評価対象となる．しかし，実運用では，旧パスワードとは独立に選ばれた新パスワードも入力される．このような新パスワードを誤って「類似」と判定する確率を評価するため，$d = \infty$ に対応する分布 $\mathcal{D}_\infty$ も評価対象に含める．なお，∞ は実際の編集距離を表す値ではなく，独立に選ばれたパスワード対を表す特別な添字である．

定義 1 (理想検出率からの距離) 方式 Σ, パラメータ λ, 閾値 θ，および距離分布 π に対し，

$$D_\theta^\pi(\Sigma, \lambda) = \sum_{d \in \mathcal{I}} \pi_d \left| r_\Sigma^\lambda(d) - I_\theta(d) \right| \tag{3}$$

と定義する．この値が小さいほど検出率は理想に近く，$D_\theta^\pi(\Sigma, \lambda) = 0$ のとき理想と一致する．

命題 1 まず d を距離分布 π に従って選び，次にパスワード対 (P, P') を $\mathcal{D}_d$ に従って選ぶ．このとき，$D_\theta^\pi(\Sigma, \lambda)$ は，チェッカーの判定が理想判定 $I_\theta(d)$ と異なる確率に等しい．

証明. $I_\theta(d) \in \{0, 1\}$ である．したがって，$d \le \theta$ では

$$\left| r_\Sigma^\lambda(d) - I_\theta(d) \right| = 1 - r_\Sigma^\lambda(d)$$

であり，$d > \theta$ では

$$\left| r_\Sigma^\lambda(d) - I_\theta(d) \right| = r_\Sigma^\lambda(d)$$

である．ここで，$d > \theta$ には $d = \infty$ も含める．よって，

$$D_\theta^\pi(\Sigma, \lambda) = \underbrace{\sum_{\substack{d \in \mathcal{I} \\ d \le \theta}} \pi_d \big(1 - r_\Sigma^\lambda(d)\big)}_{D^{\mathrm{FN}}} + \underbrace{\sum_{\substack{d \in \mathcal{I} \\ d > \theta}} \pi_d \, r_\Sigma^\lambda(d)}_{D^{\mathrm{FP}}} \tag{4}$$

と書ける．D^{FN} は，拒否すべき類似パスワードを誤って受理する確率である．一方，D^{FP} は，受理すべきパスワードを誤って拒否する確率である．したがって，両者の和はチェッカーの誤判定確率に等しい． ■

命題 1 により，提案指標は誤判定確率として直接解釈できる．例えば，$D_\theta^\pi(\Sigma, \lambda) = 0.04$ は，距離分布 π を仮定したとき，チェッカーが約 4% の確率で誤判定することを表す．式 (4) の D^{FN} は，拒否すべき類似パスワードを受理する安全性上の誤りに対応する．一方，D^{FP} は，受理すべきパスワードを拒否する利便性上の誤りに対応する．したがって，同じ $D_\theta^\pi(\Sigma, \lambda)$ を与える設定でも，誤りがどちらに偏っているかを区別して議論できる．比較対象として，方式 Σ およびパラメータ λ の検出率と理想検出率との二乗平均平方根誤差（Root Mean Squared Error; RMSE）を

$$\mathrm{RMSE}_\theta(\Sigma, \lambda) = \sqrt{\frac{1}{D} \sum_{d=1}^{D} \big(r_\Sigma^\lambda(d) - I_\theta(d)\big)^2} \tag{5}$$

と定義する．これは，定義 1 において (i) 絶対値を二乗に置き換え，(ii)$\pi_d = 1/D$（一様）とし，(iii)$\pi_\infty = 0$ とした特別な場合である．すなわち提案指標はその一般化であり，(i) 値が確率として読めない，(ii) ほとんど生じない大きな d を $d = 1$ と同等に扱う，(iii) 正当な新パスワードが拒否される事象を評価から除外する，という三つの問題を π の選択として明示的に扱えるようにしたものである．π は運用実態の仮定であって観測値ではないため，第 4.5 節で π および θ を変化させた感度分析を行う．Secure Sketch では，特徴ベクトル間の差をどこまで許容するかを，誤り訂正符号の訂正能力 t によって設定する．t が大きいほど，より離れた特徴ベクトルも類似と判定される．検出率を実験的に求める際，候補となる訂正能力 t ごとに Secure Sketch の登録処理と判定処理を実行する必要はない．次の補題が示

© 2026 Information Processing Society of Japan

すように，特徴ベクトル間の距離 $\delta(w, w')$ を一度計算すれば，その値と各 t を比較するだけで判定結果を求められる．

補題 1　code-offset 構成による Secure Sketch を，限界距離復号器とタグ検証（衝突困難ハッシュ h により $h(c)$ を保存し，復号結果 $\hat{c}$ に対し $h(\hat{c}) = h(c)$ を確認する）により運用するとき，特徴ベクトルを w, w'，訂正能力を t，距離を δ とすると，ハッシュ衝突が生じない限り $\mathsf{Check}_t = 1 \iff \delta(w, w') \le t$ が成り立つ．

証明. $\delta \le t$ のとき限界距離復号器は誤りを一意に訂正し $\hat{c} = c$ を返すのでタグは一致し受理される．$\delta > t$ のとき復号は失敗するか $\hat{c} \neq c$ へ誤訂正するが，前者は明らかに拒否され，後者も h の衝突困難性より拒否される．■

補題 1 より，訂正能力 t における検出率は

$$r_{\Sigma}^{t}(d) = \Pr_{(P,P')\sim\mathcal{D}_d}\left[\delta(w, w') \le t\right] \tag{6}$$

と表せる．すなわち，距離 d のパスワード対のうち，特徴ベクトル間距離が t 以下である対の割合が検出率となる．したがって，特徴ベクトル間距離をあらかじめ計算しておけば，各 t について距離が t 以下である対の割合を数えるだけで検出率を求められる．Secure Sketch の復号処理を t ごとに繰り返す必要はない．

4.2　提案方式：Bloom Filter + BCH Secure Sketch

MinHash+RS 方式には二つの非効率がある．第一に，Min-wise hashing は n-gram を 64 値の宇宙へ圧縮するため情報が失われる．(石井さんの実装がそうだっただけ) 第二に石井らの実装では, Reed–Solomon 符号はシンボル単位の訂正を行うため，1 シンボル内の 1 ビットだけが異なる場合でも 1 シンボル分の訂正能力を消費し，そのエントロピー損失は $2\log_2 q = 12$ ビットに達する．そこで本研究では，Berardi 方式のブルームフィルタをそのまま特徴ベクトルとして用い，二元 BCH 符号による Secure Sketch を適用する Bloom+BCH 方式を提案する．長さ m のブルームフィルタ，k 個のハッシュ関数，n-gram 長 n，二元 BCH 符号 $C \subset \mathbb{F}_2^m$（次元 k_{bch}，訂正能力 t），衝突困難ハッシュ h を公開パラメータとする．**登録** $\mathsf{Enroll}(P)$．P を n-gram に分割して長さ m のブルームフィルタ w に格納し，符号語 $c \xleftarrow{\$} C$ をランダムに選び，$s = w \oplus c$ と $\mathrm{tag} = h(c)$ を保存する．w および P は保存しない．**判定** $\mathsf{Check}(s, \mathrm{tag}, P')$．$P'$ から同様に w' を計算し，$c' = w' \oplus s = c \oplus (w \oplus w')$ を BCH 復号して $\hat{c}$ を得る．復号に成功し $h(\hat{c}) = \mathrm{tag}$ ならば 1（類似），そうでなければ 0 を出力する．補題 1 より，この判定は $\mathrm{wt}(w \oplus w') \le t$ と同値であり，二つのブルームフィルタのハミング距離が t 以下のときに限り類似と判定される．距離そのものは返さないため，Bubble 攻撃の前提となる距離応答は得られない．また公開される情報量は，Berardi 方式が m ビット全てであるのに対し，本方式では $m - k_{\mathrm{bch}}$ ビットに抑えられる．

4.3　実験設定

rockyou.txt の長さ 6–16 文字のパスワード 2,000,000 件を用いた．基準パスワード 500 件を抽出し，各基準パスワードに対して編集操作を適用した変種を生成したのち**真の** *Levenshtein* **距離を測り直し**，ちょうど d のもののみを採用した（棄却サンプリング）．石井らは編集操作の適用回数を編集距離とみなしていたが，挿入と削除の打ち消しにより実際の距離は小さくなりうるためである．無関係なパスワードは編集距離が $D = 6$ を超えることを確認して負例とした．運用方針は $\theta = 2$，母集団は「新パスワードが旧パスワードの改変である確率」$p = 0.5$, 改変量の幾何減衰率 0.45 とした．すなわち $\pi_1 = 0.277$，$\pi_2 = 0.125$，$\pi_3 = 0.056$，$\pi_4 = 0.025$，$\pi_5 = 0.011$，$\pi_6 = 0.005$，$\pi_\infty = 0.500$ である．標本は基準パスワードあたり計 200 件を π_d に比例配分した．基準パスワードの抽出，変種の生成，および後述のブートストラップ再抽出に用いる疑似乱数生成器の種は，全設定で同一の値に固定した．n-gram 長 $n \in \{2, 3, 4, 5\}$，MinHash+RS 方式は $n_{\mathrm{sig}} \in \{15, 30, 63\}$，Bloom+BCH 方式は $m \in \{63, 127, 255\}$，$k \in \{2, 3\}$ の計 36 設定を，各符号で達成可能なすべての訂正能力 t について評価した．パラメータ選択と性能報告に同じデータを用いると探索したパラメータ数が多い方式が有利になるため，基準パスワードを選択用と評価用に二分し，選択用集合でパラメータを決定したうえで評価用集合の値を報告した．方式間の優劣は，両方式に同一の基準パスワード・変種・独立ペアを与え，基準パスワード単位で同一の添字を再抽出する対応のあるブートストラップ（2000 反復）により差 Δ の 95% 信頼区間として述べる．

4.4　比較結果

表 3 と表 4 に結果を示す．いずれの方式も n-gram 長 $n = 2$ が最良であった．提案方式 Bloom+BCH は $D_\theta = 0.0426$，すなわち運用時に判定の約 4.3% を誤るのに対し，MinHash+RS 方式は $D_\theta = 0.1038$（約 10.4%）であった．対応のあるブートストラップ検定による差は $\Delta = D(\text{MinHash+RS}) - D(\text{Bloom+BCH}) = 0.0612$, 95% 信頼区間 $[0.0555, 0.0668]$ であり，区間は 0 を含まない．したがって提案方式が有意に理想に近い．誤りの内訳を見ると，両方式の差はほぼ全て**見逃し**に由来する．MinHash+RS 方式の誤判定 0.1038 のうち 0.0920 が見逃しであり，編集距離 1 のパスワードの検出率が 0.903，距離 2 では 0.480 にとどまる．一方 Bloom+BCH 方式は距離 1 で 1.000, 距離 2 で 0.864 を達成する．すなわち MinHash+RS 方式は，類似パスワードの再利用を許してしまうという安全性側の失敗が支配的である．実際，MinHash+RS 方式の最良設定は $t = 31$，すなわち情報長 $k_{\mathrm{rs}} = 63 - 2 \times 31 = 1$ のほぼ限界まで訂正能力を上げてなお見逃しが残っており，Reed–Solomon 符号の訂正能力を増やすだけではこの差を

© 2026 Information Processing Society of Japan

表 3 真の編集距離 d に対する検出率 $r(d)$（各方式の最良設定，$\theta = 2$）．I_θ は理想検出率，$d = \infty$ は無関係なパスワードに対する誤検出率．I_θ と $r(d)$ の差の π_d 重み付き総和が D_θ である．

Table 3 Detection rate $r(d)$ versus true edit distance for the best setting of each scheme.

d	1	2	3	4	5	6	∞
$I_\theta(d)$	1	1	0	0	0	0	0
Bloom+BCH	1.000	0.864	0.400	0.111	0.023	0.005	0.0002
MinHash+RS	0.903	0.480	0.173	0.067	0.023	0.005	0.0003

表 4 理想検出率からの距離 D_θ（= 運用時の期待誤判定確率，$\theta = 2$）．L は sketch により公開される情報量の上界，D^{miss} は D_θ のうち見逃しに由来する成分．

Table 4 Distance from the ideal detection rate D_θ, equal to the expected misjudgement probability.

方式	t	記憶量	L	D_θ	D^{miss}
Bloom+BCH	18	255	124	**0.0426**	0.0170
MinHash+RS	31	378	372	0.1038	0.0920

埋められない．無関係なパスワードに対する誤検出率は両方式とも極めて小さく（それぞれ 1.6×10^{-4}，3.2×10^{-4}），D_θ への寄与は無視できる水準であった．実パスワードは共通の n-gram を多く含むため誤検出が増えることを想定していたが，本実験の範囲では観測されなかった．表 5 に記憶量を揃えた比較を示す．Bloom+BCH 方式は $m = 63$ ビット（$D_\theta = 0.0497$）の時点で，MinHash+RS 方式の最良設定である 378 ビット（$D_\theta = 0.1038$）を下回っている．すなわち 1/6 の記憶量でより理想に近い判定を実現している．n-gram 長については，両方式とも $n = 2$ が最良であり，n を大きくすると急速に悪化した（Bloom+BCH で $n = 5$ のとき 0.2168，MinHash+RS で 0.3115）．これは n が大きいほど 1 回の編集操作で破壊される n-gram の個数が増えるためである．表 6 に，公開される情報量 L に上限を設けたときの各方式の最良値，すなわち Pareto 前線上の代表点を示す．提案方式の値は全ての上限において MinHash+RS 方式を下回っており，同じ公開情報量に対してより理想に近い判定を与える．とくに $L \leq 48$ ビットの制約下では 0.0497 対 0.2492 と 5 倍の差がある．これは二元 BCH 符号がビット単位の訂正に要する損失を Reed–Solomon 符号のシンボル単位訂正より小さく抑えられることを反映している．

4.5 考察

母集団 π の仮定（改変確率 $p \in \{0.2, 0.5, 0.8\}$，減衰率 0.3, 0.45, 0.7 および一様）と運用方針 $\theta \in \{1, 2, 3\}$ を組み合わせた 36 条件すべてにおいて，提案方式が理想に近いという結論は変わらなかった．π は観測値ではなく仮定であるが，本結論はその仮定に依存しない．第 3 章は，m を大きくするほど Bubble 攻撃が容易になることを示した．一方，本章の表 5 が示すように類似性判定の精度は m が大きいほど向上する．Berardi 方式はこの両者を同時に満たせないが，提案方式は同一のブルームフィルタを特徴ベクトルとして用いながら距離応答を返さないため，m を大きくして判定精度を保ちつつ距離応答を前提とする攻撃を無効化できる．公開される情報量も $m = 255$，$t = 18$ の場合 124 ビットであり，ブルームフィルタ全体を保存する Berardi 方式と比べ 51% の削減である．本研究の限界を三点挙げる．第一に，類似パスワードは実パスワードに編集操作を適用して合成したものであり，実際のユーザによるパスワード変更履歴ではない．第二に，第 3 章の実験は長さ 8 のパスワードに限定している．第三に，提案方式の安全性については公開される情報量の上界を指標として扱ったにとどまり，sketch からの復元困難性の定量的評価は行っていない．

5. おわりに

本研究では，漏洩パスワードデータセットを用いて Berardi 方式に対する Bubble 攻撃を再評価し，ブルームフィルタ長 m が攻撃難易度を支配すること，実パスワードでは辞書攻撃が比較基準となり Bubble 攻撃の価値は辞書外パスワードにあること，ブルームフィルタがパスワード長を漏えいすることを示した．また，パスワード類似性チェッカーの有用性を評価する指標として理想検出率からの距離 D_θ を定義し，これが運用時の期待誤判定確率に等しく，理想曲線からの RMSE を特別な場合として含むことを示した．さらに Berardi 方式に BCH 符号による Secure Sketch を組み込んだ方式を提案し，提案指標の下で MinHash+RS 方式より有意に理想に近いこと（$\Delta = 0.0612$，95% 信頼区間 $[0.0555, 0.0668]$），かつ 1/6 の記憶量でこれを達成することを示した．今後の課題として，実際のパスワード変更履歴を用いた母集団 π の推定，Fuzzy Extractor[4] との組

© 2026 Information Processing Society of Japan

表 5　記憶量を揃えた比較（各記憶量における最良設定，$n = 2$）．

Table 5　Comparison at matched storage size.

方式	記憶量	t	L	D_θ	$r(1)$
Bloom+BCH	63	10	45	0.0497	1.000
Bloom+BCH	127	15	91	0.0484	1.000
Bloom+BCH	255	18	124	**0.0426**	1.000
MinHash+RS	90	7	84	0.1212	0.855
MinHash+RS	180	14	168	0.1181	0.866
MinHash+RS	378	31	372	0.1038	0.903

表 6　公開情報量 L の上限を変えたときの理想からの距離 D_θ（Pareto 前線上の代表点，$n = 2$）．括弧内は達成設定（符号長／訂正能力 t ／実際の L）．左ほど公開情報が少なく安全である．

Table 6　Trade-off between the disclosed information L and the distance from the ideal D_θ.

L の上限	Bloom+BCH	MinHash+RS
24	0.2482 (63, 4, 24)	0.3329 (15, 2, 24)
48	**0.0497** (63, 10, 45)	0.2492 (15, 4, 48)
96	**0.0433** (255, 12, 92)	0.1212 (15, 7, 84)
192	**0.0426** (255, 18, 124)	0.1181 (30, 14, 168)
384	**0.0426** (255, 18, 124)	0.1038 (63, 31, 372)

合せによる鍵生成方式への拡張，およびオンライン攻撃モデルを含む包括的な安全性評価が挙げられる．

謝辞　本研究は，JST 経済安全保障重要技術育成プログラム JPMJKP24U1 の支援を受けたものです．

参考文献

[1] D. Florencio and C. Herley: “A large-scale study of web password habits”, Proceedings of the 16th International World Wide Web Conference (WWW), pp. 657–666 (2007).

[2] M. Weir, S. Aggarwal, B. de Medeiros and B. Glodek: “Testing metrics for password creation policies by attacking large sets of revealed passwords”, Proceedings of the 17th ACM Conference on Computer and Communications Security (CCS), pp. 162–175 (2010).

[3] D. Berardi, F. Callegati, A. Melis and M. Prandini: “Password similarity using probabilistic data structures”, Journal of Cybersecurity and Privacy, **1**, 1, pp. 78–92 (2021).

[4] Y. Dodis, L. Reyzin and A. Smith: “Fuzzy extractors: How to generate strong keys from biometrics and other noisy data”, SIAM Journal on Computing, **38**, 1, pp. 97–139 (2008).

[5] A. Z. Broder: “On the resemblance and containment of documents”, Proceedings of the Compression and Complexity of Sequences, IEEE, pp. 21–29 (1997).

[6] B. H. Bloom: “Space/time trade-offs in hash coding with allowable errors”, Communications of the ACM, **13**, 7, pp. 422–426 (1970).

[7] A. Broder and M. Mitzenmacher: “Network applications of bloom filters: A survey”, Internet Mathematics, **1**, 4, pp. 485–509 (2004).

[8] I. S. Reed and G. Solomon: “Polynomial codes over certain finite fields”, Journal of the Society for Industrial and Applied Mathematics, **8**, 2, pp. 300–304 (1960).

[9] W. C. Huffman and V. Pless: “Fundamentals of Error-Correcting Codes”, Cambridge University Press (2003).

[10] A. Hocquenghem: “Codes correcteurs d’erreurs”, Chiffres, **2**, pp. 147–156 (1959).

[11] R. C. Bose and D. K. Ray-Chaudhuri: “On a class of error correcting binary group codes”, Information and Control, **3**, 1, pp. 68–79 (1960).

[12] D. Miessler, J. Haddix and g0tmi1k (eds.): “SecLists: The security tester’s companion”, `Passwords/Leaked-Databases/rockyou.txt.tar.gz`, `https://github.com/danielmiessler/SecLists` (2026 年 8 月 16 日閲覧).

[13] 石井尊, 野島良, 王立華: “パスワード類似性チェッカーに対するバブル攻撃とその対策について”, 2026 年 暗号と情報セキュリティシンポジウム (SCIS 2026) (2026).

© 2026 Information Processing Society of Japan